GOOGLE.ORG CYBERSECURITY SEMINARS

ARISTOTLE UNIVERSITY OF THESSALONIKI

ΕΡΓΑΣΙΑ 2

Τεχνικές και Διαδικασίες Ψευδωνυμοποίησης σε Περιβάλλον GDPR

ΑΣΚΗΣΗ 1η

Μια εταιρεία τηλεϊατρικής θέλει να δώσει σε ένα πανεπιστήμιο δεδομένα ασθενών για ερευνητικούς σκοπούς, όμως πριν τα διαβιβάσει πρέπει να τα προστατεύσει εφαρμόζοντας ψευδωνυμοποίηση. Τα δεδομένα που έχει είναι ονοματεπώνυμο, ΑΜΚΑ, τηλέφωνο, διεύθυνση, αποτελέσματα εξετάσεων και ιστορικό θεραπειών. Ζητείται να εντοπίσεις ποια από αυτά τα στοιχεία αποτελούν άμεσα αναγνωριστικά, ποια είναι έμμεσα αναγνωριστικά και ποια θεωρούνται ευαίσθητα δεδομένα, να προτείνεις έναν κατάλληλο τρόπο ψευδωνυμοποίησης για να αντικατασταθούν τα αναγνωριστικά στοιχεία με τεχνητούς κωδικούς, να περιγράψεις πώς πρέπει να αποθηκεύεται με ασφάλεια ο πίνακας αντιστοίχισης (που συνδέει τους κωδικούς με τα πραγματικά στοιχεία), να παρουσιάσεις τα βασικά βήματα της διαδικασίας από τη συλλογή μέχρι τη διαβίβαση των ψευδωνυμοποιημένων δεδομένων, και τέλος να εξηγήσεις γιατί η ψευδωνυμοποίηση μειώνει τον κίνδυνο παραβίασης αλλά και σε ποιες περιπτώσεις μπορεί να μην είναι επαρκής.

Στην άσκηση θα χρειαστεί να ταξινομήσεις τα δεδομένα του οργανισμού σε κατηγορίες (άμεσα αναγνωριστικά, έμμεσα αναγνωριστικά, ευαίσθητα δεδομένα), να προτείνεις έναν πρακτικό τρόπο με τον οποίο θα μπορούσαν να αντικατασταθούν τα πραγματικά στοιχεία των ασθενών με ψευδώνυμα όπως “PAT001” ή “PAT002”, να περιγράψεις πού και πώς θα πρέπει να φυλάσσεται ο πίνακας αντιστοίχισης που κρατά τα πραγματικά στοιχεία, να παρουσιάσεις τη σειρά ενεργειών που πρέπει να ακολουθήσει ο οργανισμός ώστε να εφαρμόσει σωστά την ψευδωνυμοποίηση πριν στείλει τα δεδομένα, και να εξηγήσεις με δικά σου λόγια γιατί αυτή η διαδικασία μειώνει τον κίνδυνο αποκάλυψης ταυτότητας και σε ποιες περιπτώσεις μπορεί να μην είναι αρκετή από μόνη της.

ΑΣΚΗΣΗ 2η

Ένας οργανισμός θέλει να μοιραστεί δεδομένα πελατών του με έναν εξωτερικό συνεργάτη για στατιστική ανάλυση.
Σύμφωνα με τον GDPR, πριν σταλούν τα δεδομένα, πρέπει να γίνει **ψευδωνυμοποίηση**, δηλαδή αντικατάσταση των πραγματικών στοιχείων (ονόματα, emails) με τεχνητά αναγνωριστικά, ώστε να μην αποκαλύπτεται η ταυτότητα των ανθρώπων.

Ο αρχικός πίνακας δεδομένων είναι:

customers = [

{"name": "Άννα", "email": "anna@example.com", "age": 28},

{"name": "Κώστας", "email": "kostas@example.com", "age": 35},

{"name": "Ιωάννα", "email": "ioanna@example.com", "age": 22}

]

Ζητείται:

1. Να αντικαταστήσεις τα στοιχεία που μπορούν να ταυτοποιήσουν άμεσα ένα άτομο (όνομα και email) με ένα **ψευδώνυμο** της μορφής `"USER1"`, `"USER2"`, `"USER3"`.
2. Να δημιουργήσεις έναν **πίνακα αντιστοίχισης** (mapping table), όπου θα καταγράφονται το ψευδώνυμο και τα πραγματικά στοιχεία.

   Σημείωση: Στον πραγματικό GDPR, αυτός ο πίνακας πρέπει να αποθηκεύεται **ξεχωριστά** και με αυξημένα τεχνικά μέτρα.

3. Να εμφανίσεις:
   - τον πίνακα με τα ψευδωνυμοποιημένα δεδομένα,
   - τον πίνακα αντιστοίχισης.
4. Να εξηγήσεις με ένα σύντομο σχόλιο μέσα στο πρόγραμμα **γιατί η ψευδωνυμοποίηση βοηθά στην προστασία των προσωπικών δεδομένων**, σύμφωνα με τον GDPR.